

CHƯƠNG 1. CƠ SỞ LÝ THUYẾT

1.1. Tổng quan về giao thức SMB

1.1.1. Khái niệm và vai trò của SMB

Server Message Block (SMB) là giao thức mạng hoạt động ở tầng ứng dụng (Application Layer), cung cấp cơ chế chia sẻ tệp tin, thư mục, máy in và hỗ trợ giao tiếp liên tiến trình (Inter-Process Communication - IPC) giữa các máy tính qua mạng.

Trên hệ điều hành Windows, SMB là giao thức truyền thông mặc định cho các dịch vụ mạng nội bộ, hoạt động trực tiếp trên nền giao thức TCP qua cổng 445 hoặc kết hợp với tầng NetBIOS over TCP/IP qua cổng 139.

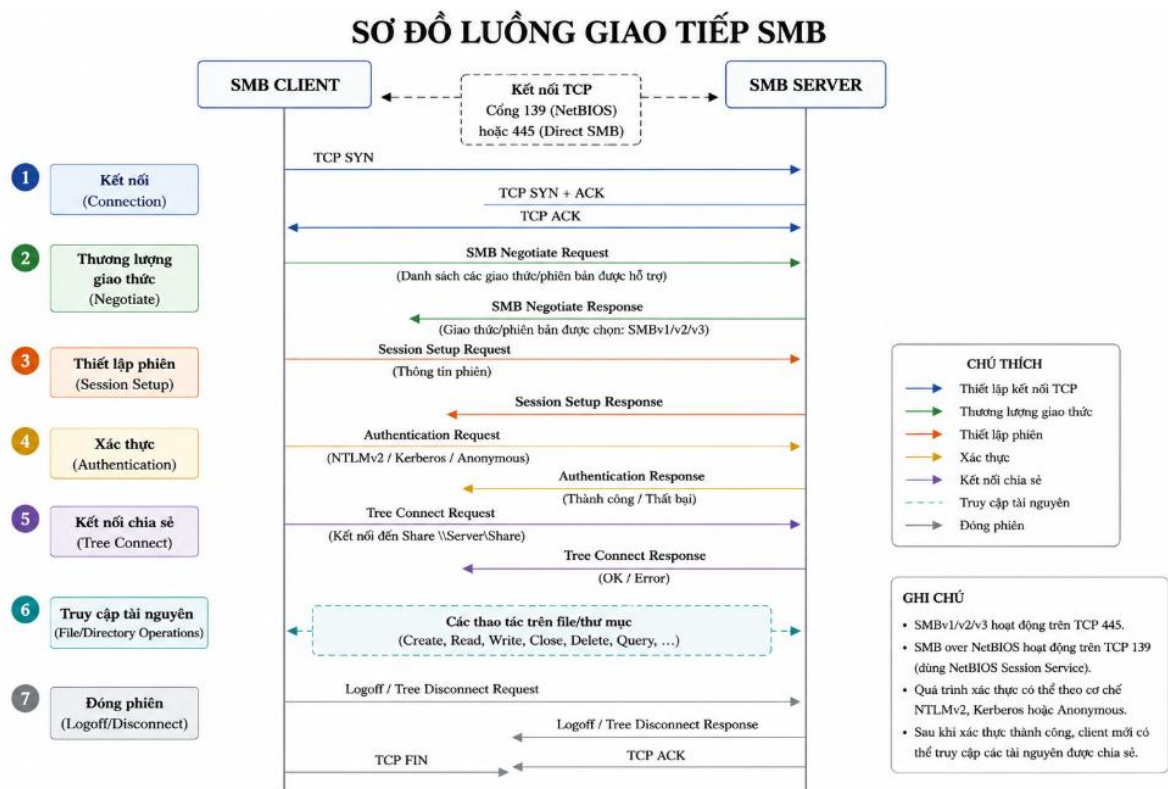
Giao thức vận hành theo mô hình Client - Server, trong đó bên yêu cầu tài nguyên đóng vai trò SMB Client và bên tiếp nhận, kiểm soát, chia sẻ tài nguyên đóng vai trò SMB Server.

➤ *Vai trò trong hệ thống:*

- **Chia sẻ dữ liệu và quản lý tệp tin từ xa:** Cung cấp phương thức cho người dùng và ứng dụng thực hiện các thao tác đọc, ghi, tạo mới, khóa tệp và chỉnh sửa dữ liệu trực tiếp trên các thư mục dùng chung (Network Shares) trong mạng nội bộ.
- **Chia sẻ tài nguyên thiết bị ngoại vi:** Đóng vai trò làm giao thức trung gian điều phối lệnh in ấn và quản lý hàng đợi tài liệu đối với các máy in được chia sẻ chung trong hệ thống mạng.
- **Hỗ trợ giao tiếp liên tiến trình (IPC) và quản trị từ xa:** Cung cấp cơ chế Named Pipes để truyền tải các lệnh gọi thủ tục từ xa (Remote Procedure Call - RPC), phục vụ công tác xác thực tập trung và quản trị hệ thống Windows từ xa.
- **Xác thực và kiểm soát truy cập an toàn:** Tích hợp với các cơ chế xác thực của Windows (NTLM, Kerberos) để định danh người dùng, đàm phán cấp độ bảo mật (dialect negotiation), thiết lập phiên làm việc (Session Setup) và kiểm tra quyền hạn (Access Control List - ACL) trước khi cấp quyền truy cập tài nguyên.

1.1.2. Mô hình Client – Server trên Windows

- ***Kiến trúc tổng thể:***
 - Dịch vụ SMB trên Windows được thiết kế và vận hành theo mô hình Client - Server, phân định rõ vai trò giữa bên khởi tạo yêu cầu và bên tiếp nhận, xử lý yêu cầu.
 - Phía SMB Client chịu trách nhiệm gửi các yêu cầu kết nối, xác thực và truy cập tệp tin hoặc thiết bị từ xa qua môi trường mạng.
 - Phía SMB Server chịu trách nhiệm quản lý, công bố các tài nguyên chia sẻ (Shares), tiếp nhận và phản hồi các yêu cầu từ Client theo quyền hạn đã được cấp phát.
- ***Các thành phần cốt lõi trên hệ điều hành Windows:***
 - SMB Client (Workstation Service): Dịch vụ chạy nền trên Windows, phối hợp với trình chuyển hướng mạng (Network Redirector) để điều hướng các thao tác I/O trên tệp tin từ xa qua mạng thay vì hệ thống tệp cục bộ.
 - SMB Server (Server Service): Dịch vụ tiếp nhận các kết nối mạng đến cổng 139 hoặc 445, chuyển tiếp các yêu cầu xử lý gói tin cho trình điều khiển cấp nhân (Kernel-mode driver như srv.sys đối với SMBv1 hoặc srv2.sys đối với SMBv2/SMBv3).
- ***Quy trình tương tác giữa Client và Server:***



Hình 1

- **Bước 1 - Thiết lập kết nối truyền tải:** Client mở kết nối TCP tới cổng 445 (hoặc NetBIOS qua cổng 139) của Server.
- **Bước 2 - Thương lượng giao thức (Negotiate Protocol):** Client gửi danh sách các dialect (phiên bản SMB) hỗ trợ; Server phản hồi để chọn dialect cao nhất mà hai bên cùng tương thích.
- **Bước 3 - Xác thực và thiết lập phiên (Session Setup):** Hai bên trao đổi thông tin định danh (sử dụng cơ chế NTLM hoặc Kerberos) để xác thực người dùng và cấp phát định danh phiên (Session ID).
- **Bước 4 - Kết nối tài nguyên chia sẻ (Tree Connect):** Client gửi yêu cầu kết nối tới một thư mục chia sẻ cụ thể (như C\$, IPC\$, hoặc thư mục được chia sẻ công khai) và nhận về một mã định danh kết nối (Tree ID).
- **Bước 5 - Thao tác dữ liệu:** Client thực hiện các lệnh đọc, ghi, tạo mới hoặc đóng tệp tin trên Server dựa trên quyền hạn đã được kiểm tra.

- **Đặc điểm vận hành trên Windows:**

Tính linh hoạt về vai trò: Một máy tính chạy Windows có thể đồng thời đóng vai trò SMB Client khi truy xuất tài nguyên của máy khác và làm SMB Server khi chia sẻ thư mục của chính nó ra mạng nội bộ.

Hoạt động ở Kernel-mode: Trình điều khiển phía Server chạy trực tiếp trong không gian hệ điều hành nhằm đảm bảo hiệu năng I/O cao, khiến bất kỳ lỗi xử lý gói tin nào tại thành phần này đều có nguy cơ ảnh hưởng trực tiếp đến độ ổn định và an toàn của toàn bộ hệ thống.

1.1.3. SMBv1, SMBv2 và SMBv3

Giao thức Server Message Block trên Windows được phân loại thành ba phiên bản chính với sự khác biệt về cấu trúc lệnh, tốc độ truyền tải và tính an toàn:

- **Phiên bản SMBv1 (CIFS):**

- SMBv1 vận hành với hơn 100 mã lệnh và sử dụng cơ chế trao đổi dữ liệu tuần tự từng bước. Cách thức này tạo ra nhiều lượt truyền nhận qua lại không cần thiết, làm đường truyền mạng bị trễ và giảm hiệu năng rõ rệt.
- Về mặt bảo mật, SMBv1 không hỗ trợ mã hóa luồng dữ liệu và chỉ dùng thuật toán MD5 cũ để kiểm tra gói tin. Đặc biệt, driver hệ thống srv.sys của Windows khi xử lý các gói tin SMBv1 gặp lỗi quản lý bộ nhớ nghiêm trọng, dẫn đến nhóm lỗ hổng thực thi mã từ xa MS17-010 (EternalBlue) cho phép kẻ tấn công chiếm quyền điều khiển máy tính mà không cần tài khoản đăng nhập.

- **Phiên bản SMBv2:**

- Được Microsoft đưa vào từ Windows Vista và Windows Server 2008 nhằm thay thế hoàn toàn SMBv1. Điểm cải tiến lớn nhất là bộ mã lệnh được rút gọn từ hơn 100 lệnh xuống còn 19 lệnh tiêu chuẩn, đồng thời bổ sung tính năng gộp nhiều yêu cầu vào một gói tin duy nhất để tiết kiệm băng thông và giảm thời gian phản hồi.
- SMBv2 tổ chức lại việc quản lý phiên làm việc và kết nối tài nguyên rõ ràng hơn, đồng thời nâng cấp cơ chế chống sửa đổi gói tin lên

chuẩn HMAC-SHA256, giúp bảo vệ dữ liệu trao đổi không bị can thiệp trái phép trên đường truyền.

- **Phiên bản SMBv3:**

- Được phát triển từ Windows 8 và Windows Server 2012, kế thừa nền tảng của SMBv2 và bổ sung các cơ chế bảo mật mạnh mẽ cho hệ thống mạng hiện đại:

- *Mã hóa dữ liệu đầu cuối (SMB Encryption):* Dùng thuật toán chuẩn AES (AES-CCM, AES-GCM) trực tiếp ở tầng ứng dụng, giúp chống nghe lén và đánh cắp thông tin mà không cần thiết lập thêm hạ tầng IPsec phức tạp.
- *Chống sửa đổi gói tin (SMB Signing):* Sử dụng các thuật toán AES-CMAC và AES-GMAC để xác thực nguồn gốc và đảm bảo gói tin gửi đi không bị chèn ép hay chỉnh sửa.
- *Tối ưu tốc độ và dự phòng mạng:* Hỗ trợ SMB Multichannel để gộp băng thông và dự phòng lỗi qua nhiều card mạng cùng lúc; hỗ trợ SMB Direct qua công nghệ RDMA giúp truyền tệp tốc độ cao mà không làm quá tải CPU máy chủ.

Đặc tính kỹ thuật	SMBv1	SMBv2	SMBv3
Phiên bản Windows áp dụng đầu tiên	Windows 2000 / XP trở về trước	Windows Vista / Server 2008	Windows 8 / Server 2012 trở lên
Số lượng mã lệnh điều khiển	Hơn 100 mã lệnh	19 mã lệnh tiêu chuẩn	19 mã lệnh tiêu chuẩn
Cơ chế xử lý yêu cầu mạng	Tuần tự từng gói (gây nghẽn và độ trễ cao)	Ghép nhiều lệnh vào 1 gói tin duy nhất (Compounding)	Tối ưu ghép lệnh và xử lý dữ liệu bất đồng bộ
Cổng mạng & kênh truyền thông	Cổng TCP 139 (NetBIOS) và TCP 445	Cổng TCP 445 (SMB Direct Hosting)	Cổng TCP 445, RDMA và UDP 443 (SMB over QUIC)
Cơ chế chống sửa đổi gói tin (Signing)	Thuật toán băm MD5 (dễ bị tấn công giả mạo)	Thuật toán HMAC-SHA256	Thuật toán mã hóa chuẩn AES-CMAC và AES-GMAC
Mã hóa luồng dữ liệu (SMB Encryption)	Không hỗ trợ (dữ liệu gửi đi ở dạng văn bản rõ)	Không hỗ trợ	Mã hóa toàn diện đầu cuối bằng AES-128 / AES-256
Tối ưu tốc độ và giảm tải CPU máy chủ	Không hỗ trợ	Mở rộng kích thước bộ đệm đọc/ghi	Hỗ trợ SMB Direct qua công nghệ RDMA
Khả năng gộp đường truyền và dự phòng	Không hỗ trợ	Không hỗ trợ	Hỗ trợ SMB Multichannel (chạy song song nhiều card mạng)
Nguy cơ bảo mật & Bề mặt tấn công	Lỗi quản lý bộ nhớ trong srv.sys (MS17-010, WannaCry)	Rủi ro bị tấn công chuyển tiếp gói tin (SMB Relay) nếu tắt Signing	Triệt tiêu tấn công nghe lén (Eavesdropping) và sửa gói tin (Man-in-the-Middle)

1.1.4. Quy trình thỏa thuận phiên bản kết nối SMB

➤ Khái niệm về SMB Dialect:

Trong giao thức SMB, Dialect là thuật ngữ dùng để chỉ phiên bản cụ thể hoặc tập hợp quy chuẩn giao tiếp mà Client và Server sử dụng để hiểu nhau. Mỗi thế hệ Windows được phát triển đều hỗ trợ thêm các dialect mới, đồng thời duy trì khả năng tương thích ngược với các dialect cũ hơn. Ví dụ:

- *SMBv1*: Sử dụng các chuỗi định danh dạng văn bản, tiêu biểu là NT LM 0.12 (chuẩn SMBv1 phổ biến nhất trên Windows NT/2000/XP).
- *SMBv2*: Sử dụng mã số hiệu, gồm SMB 2.0.2 (Windows Vista), SMB 2.1 (Windows 7/Server 2008 R2).
- *SMBv3*: Gồm SMB 3.0 (Windows 8/Server 2012), SMB 3.0.2 (Windows 8.1) và SMB 3.1.1 (Windows 10/Server 2016 trở lên).

➤ Mục đích của quá trình thương lượng (Negotiate Protocol):

Thương lượng dialect là bước giao tiếp bắt buộc đầu tiên ngay sau khi hai máy tính thiết lập thành công kết nối TCP (qua cổng 445 hoặc 139). Quá trình này giúp hai bên thống nhất phiên bản giao thức cao nhất mà cả hai cùng hỗ trợ, đồng thời thiết lập các tham số vận hành ban đầu như: kích thước bộ nhớ đệm tối đa, cơ chế xác thực hỗ trợ, yêu cầu bật/tắt tính năng chống sửa đổi gói tin (SMB Signing) và khóa mã hóa.

➤ Quy trình đàm phán giữa Client và Server:

Quá trình này diễn ra qua hai bản tin trao đổi cơ bản:

- *Gói tin yêu cầu thương lượng (Negotiate Request)*: Client gửi đến Server một danh sách chứa tất cả các dialect mà nó có thể hỗ trợ, sắp xếp theo thứ tự từ phiên bản mới nhất đến các phiên bản cũ hơn.
- *Gói tin phản hồi thương lượng (Negotiate Response)*: Server tiếp nhận danh sách, đối chiếu với các dialect mà nó đã kích hoạt và chọn ra phiên bản cao nhất chung giữa hai hệ thống để phản hồi lại Client. Nếu hai bên không tìm được phiên bản tương thích chung, kết nối mạng sẽ bị hủy bỏ ngay lập tức.

1.1.5. Xác thực và thiết lập phiên

➤ Mục đích của việc thiết lập phiên:

Sau khi hoàn tất thỏa thuận phiên bản giao thức, Client và Server phải thực hiện quy trình xác thực và thiết lập phiên làm việc (Session Setup). Mục đích của quá trình này là kiểm tra danh tính người dùng hoặc máy tính yêu cầu kết nối, gán quyền hạn tương ứng và cấp một mã định danh phiên (Session ID đối với SMBv2/v3 hoặc UID đối với SMBv1) để duy trì kênh giao tiếp an toàn cho các yêu cầu kế tiếp.

➤ Các cơ chế xác thực phổ biến:

- *Xác thực NTLM (NTLMv1/NTLMv2)*: Hoạt động theo cơ chế hỏi - đáp (Challenge - Response), thường được sử dụng trong mô hình mạng ngang hàng (Workgroup) hoặc dùng để tương thích ngược khi hệ thống chưa có hạ tầng quản lý người dùng tập trung.
- *Xác thực Kerberos*: Là cơ chế mặc định và có tính an toàn cao trong môi trường quản lý tập trung (Active Directory Domain Services), dựa trên việc cấp và kiểm tra các vé chứng thực (Tickets) để tránh truyền dữ liệu nhạy cảm qua mạng.
- *Kết nối ẩn danh (Anonymous / Null Session)*: Cho phép Client gửi yêu cầu kết nối mà không cần tài khoản hay mật khẩu, thường dùng để truy vấn sơ bộ thông tin máy chủ hoặc kết nối tới tài nguyên chia sẻ ngầm định IPC\$.

➤ Quy trình trao đổi bản tin:

Quá trình xác thực và khởi tạo phiên làm việc diễn ra qua các bước tuần tự:

- *Gửi gói yêu cầu thiết lập phiên (Session Setup Request)*: Client gửi gói tin chứa thông tin định danh người dùng hoặc dữ liệu xác thực (NTLM token hoặc Kerberos ticket) tới Server.
- *Xác minh và phản hồi kết quả (Session Setup Response)*: Server kiểm tra tính hợp lệ của tài khoản trong cơ sở dữ liệu cục bộ hoặc gửi sang máy chủ quản lý miền (Domain Controller). Khi thông tin chính xác, Server cấp phát mã Session ID và gửi trả về Client. Kể từ thời điểm này, mọi thao tác truy cập dữ liệu của Client đều phải đính kèm mã định danh phiên này để Server kiểm soát quyền hạn.

1.1.6. Chia sẻ và truy cập tài nguyên

➤ Mục đích của việc kết nối tài nguyên (Tree Connect):

Sau khi hoàn tất bước xác thực và nhận được mã phiên (Session ID), Client cần kết nối trực tiếp đến một vùng tài nguyên cụ thể do Server cung cấp để bắt đầu làm việc. Quá trình này được gọi là gắn kết tài nguyên (Tree Connect). Máy chủ sẽ kiểm tra quyền hạn của tài khoản trên tài nguyên đó và phản hồi một mã định danh kết nối (Tree ID - TID) để theo dõi xuyên suốt quá trình thao tác.

➤ Các loại tài nguyên chia sẻ trên hệ điều hành Windows:

- *Thư mục chia sẻ thông thường*: Các thư mục dữ liệu do người dùng hoặc quản trị viên tạo ra để phục vụ nhu cầu trao đổi tệp tin trong mạng nội bộ, được kiểm soát quyền hạn bằng danh sách truy cập (Share Permissions và NTFS Permissions).
- *Tài nguyên chia sẻ quản trị (Administrative Shares)*: Các vùng chia sẻ ngầm định có ký tự \$ ở cuối tên (như C\$, D\$, ADMIN\$), phục vụ mục đích quản trị hệ thống từ xa và chỉ cho phép các tài khoản thuộc nhóm Quản trị viên (Administrators) truy cập.
- *Tài nguyên chia sẻ đặc biệt (IPC\$ - Inter-Process Communication)*: Đây là vùng chia sẻ không chứa tệp tin thực tế, mà đóng vai trò làm kênh truyền dữ liệu trung gian (Named Pipes) phục vụ giao tiếp giữa các tiến trình và hỗ trợ các lệnh gọi từ xa (RPC) giữa các máy tính Windows.

➤ Quy trình kết nối:

- *Gửi yêu cầu kết nối (Tree Connect Request)*: Client gửi gói tin chứa đường dẫn tài nguyên cần truy cập kèm theo mã Session ID đã được cấp trước đó.
- *Phản hồi cấp quyền (Tree Connect Response)*: Server đối chiếu quyền hạn truy cập của tài khoản với tài nguyên yêu cầu nếu hợp lệ, Server trả về mã định danh Tree ID (TID).
- *Thực thi lệnh đọc/ghi dữ liệu*: Mọi thao tác tệp tin kế tiếp (như tạo mới, đọc, ghi hoặc xóa tệp) đều phải sử dụng đồng thời bộ đôi mã Session ID và Tree ID để Server xác thực tính hợp lệ trước khi cho phép thực thi.

1.1.7. Cổng mạng TCP 139 và TCP 445 trong kết nối SMB

Để truyền tải dữ liệu giữa Client và Server, giao thức SMB sử dụng hai cổng dịch vụ mạng chính với cơ chế hoạt động khác nhau tùy thuộc vào phiên bản hệ điều hành:

➤ **Cổng TCP 139 (Kết nối qua NetBIOS):**

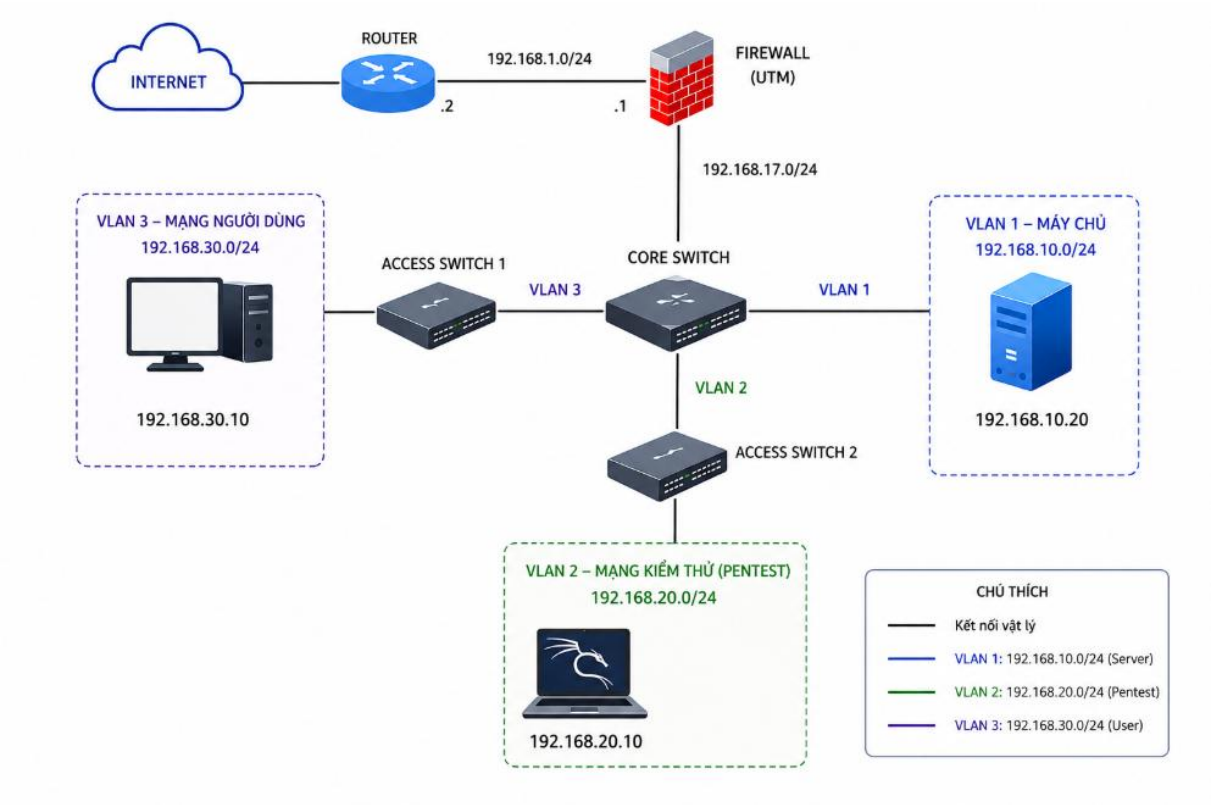
- Được sử dụng chủ yếu trên các phiên bản Windows đời cũ (Windows 95, 98, NT). Ở phương thức này, dữ liệu SMB không truyền trực tiếp qua giao thức TCP mà phải bọc trong một lớp trung gian là NetBIOS qua TCP/IP (NBT).
- Trước khi gửi các lệnh SMB, hai máy tính phải hoàn tất bước thiết lập phiên NetBIOS (NetBIOS Session Service).
- Quá trình tìm kiếm máy tính và phân giải địa chỉ phụ thuộc vào tên máy NetBIOS thay vì dùng hệ thống tên miền DNS.

➤ **Cổng TCP 445 (Kết nối trực tiếp qua TCP):**

Được Microsoft bổ sung từ phiên bản Windows 2000 trở về sau, cho phép giao thức SMB chạy trực tiếp trên nền TCP/IP mà không cần lớp trung gian NetBIOS (Direct Hosted SMB).

- Loại bỏ phần tiêu đề NetBIOS dư thừa, giúp cấu trúc gói tin đơn giản hơn và tăng tốc độ truyền dữ liệu.
- Hệ thống phân giải tên máy tính trực tiếp bằng DNS hoặc kết nối thẳng bằng địa chỉ IP, phù hợp với tiêu chuẩn mạng Internet hiện đại.
- Cơ chế tự động lựa chọn cổng kết nối:
 - Khi người dùng thực hiện truy cập đến một thư mục chia sẻ, hệ điều hành Windows sẽ tự động gửi đồng thời hai gói tin bắt tay TCP đến cả cổng 445 và cổng 139 của máy đích:
 - Nếu cổng 445 phản hồi trước, kết nối SMB trực tiếp sẽ được thiết lập và gói tin kết nối đến cổng 139 bị hủy bỏ.
 - Nếu cổng 445 bị chặn hoặc máy đích không hỗ trợ, kết nối sẽ tự động lùi về (fallback) sử dụng cổng 139 qua NetBIOS.

2.1. Sơ đồ kiến trúc mô hình Lab



Hình 2